

Clase 281 — Cumplimiento: GDPR, HIPAA y PCI-DSS

Parte: **14 — GRC, riesgo y cumplimiento** · Fuente: *Reglamento (UE) 2016/679, HIPAA Security Rule y PCI DSS v4.0* 🕒 Duración estimada: **120 min** · Nivel: **Intermedio**

🎯 Objetivo

Comprender las tres regulaciones de cumplimiento más influyentes para la seguridad de la información — GDPR (privacidad europea), HIPAA (salud en EE. UU.) y PCI-DSS (pagos con tarjeta)— e identificar cuáles aplican a un escenario y qué obligaciones concretas imponen. Al terminar sabrás determinar la aplicabilidad, mapear requisitos a controles técnicos y evitar multas y sanciones por incumplimiento.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Distinguir** el alcance y el sujeto protegido de GDPR, HIPAA y PCI-DSS.
2. **Determinar** qué regulaciones aplican a un escenario concreto.
3. **Mapear** requisitos regulatorios a controles técnicos verificables.
4. **Explicar** las obligaciones de notificación de brechas de cada marco.
5. **Reducir** el alcance PCI mediante segmentación y tokenización.

📖 Temas

#	Tema	Por qué importa
1	GDPR: principios y bases de licitud	Rige datos personales de la UE
2	Derechos del interesado y roles	Responsable vs. encargado del tratamiento
3	HIPAA: PHI y las tres Rules	Protege datos de salud en EE. UU.
4	PCI-DSS v4.0: 12 requisitos	Obligatorio si tocas datos de tarjeta
5	Reducción de alcance PCI (CDE)	Menos alcance, menos coste y riesgo
6	Notificación de brechas	Plazos y a quién notificar
7	Sanciones y multas	El coste real del incumplimiento

📖 Definiciones y características

- **GDPR**: reglamento europeo de protección de datos personales. *Clave*: multas hasta 20 M€ o 4% de la facturación global.
- **Dato personal**: cualquier información sobre una persona física identificable. *Clave*: incluye IP, cookies, identificadores.
- **Responsable / encargado del tratamiento**: quien decide los fines vs. quien procesa por cuenta ajena. *Clave*: definen las obligaciones contractuales (DPA).

- **HIPAA / PHI:** ley de salud de EE. UU. y su dato protegido (Protected Health Information). *Clave:* Security Rule exige salvaguardas administrativas, físicas y técnicas.
- **PCI-DSS:** estándar del sector de pagos con 12 requisitos. *Clave:* obligatorio por contrato con las marcas de tarjeta, no por ley.
- **CDE (Cardholder Data Environment):** entorno donde se almacenan/procesan/transmiten datos de tarjeta. *Clave:* reducir el CDE reduce el alcance de auditoría.
- **Tokenización:** sustituir el PAN por un token sin valor. *Clave:* saca sistemas del alcance PCI.

Herramientas y preparación

- Textos oficiales: GDPR en EUR-Lex, HIPAA Security Rule en HHS.gov, PCI DSS v4.0 en el PCI SSC.
- Los cuestionarios SAQ (Self-Assessment Questionnaire) de PCI, según tipo de comercio.
- Hoja de cálculo para el mapeo requisito → control.
- Opcional: un diagrama de flujo de datos (draw.io / Mermaid) para trazar dónde viven los datos personales y de tarjeta.

Laboratorio guiado (ejercicio aplicado)

Escenario: "Ferretería del Sur S.A." vende online a clientes de la UE, guarda perfiles de clientes y procesa pagos con tarjeta a través de una pasarela.

1. **Data flow mapping:** dibuja el flujo de datos personales y de tarjeta desde el navegador del cliente hasta la base de datos y la pasarela. Marca dónde se almacena cada tipo.
2. **Aplicabilidad:** en una tabla, decide qué regulación aplica a cada flujo. GDPR aplica (clientes UE); PCI-DSS aplica (datos de tarjeta); HIPAA no (no hay datos de salud). Justifica.
3. **GDPR:** identifica la base de licitud de cada tratamiento (ejecución de contrato para la compra, consentimiento para marketing) y lista 3 derechos que debes poder atender (acceso, supresión, portabilidad).
4. **Reducción de alcance PCI:** propón usar la pasarela con *hosted fields* o tokenización para que el PAN nunca toque tus servidores; explica cómo eso reduce el SAQ aplicable (de D a A).
5. **Mapeo a controles:** crea una tabla requisito → control técnico, p. ej.: PCI Req.3 (proteger datos almacenados) → cifrado + tokenización; PCI Req.8 (identificar y autenticar) → MFA; GDPR Art.32 → cifrado y seudonimización.
6. **Notificación de brechas:** redacta el procedimiento con plazos: GDPR 72 h a la autoridad de control; PCI, notificación inmediata al adquirente; documenta a quién avisa cada uno.
7. **Registro de actividades de tratamiento** (GDPR Art.30): rellena una fila con finalidad, categorías de datos, plazo de conservación y medidas de seguridad.

Ejercicios

1. Clasifica: ¿aplica GDPR a una empresa de EE. UU. que vende a clientes en España? Justifica.
2. Diferencia responsable y encargado con un ejemplo del escenario.
3. ¿Qué SAQ aplica si tercerizas todo el pago con hosted fields? ¿Y si almacenas el PAN?
4. Enumera las tres categorías de salvaguardas de la HIPAA Security Rule.
5. Un cliente pide borrar sus datos, pero tienes obligación fiscal de conservar facturas 6 años. ¿Cómo lo resuelves?
6. Mapea el requisito PCI de segmentación de red a un control técnico concreto.

Reto verificable

Entrega un **análisis de aplicabilidad regulatoria** del escenario con: mapa de flujo de datos, tabla de qué regulación aplica y por qué, mapeo de al menos 8 requisitos a controles técnicos, y el procedimiento de notificación de brechas con plazos por marco.

Criterio de aceptación: cada regulación se declara aplicable o no con justificación, el mapeo requisito→control es verificable, y los plazos de notificación (72 h GDPR incluido) son correctos.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Almacenar el PAN sin necesidad	Amplía el alcance PCI; tokeniza o usa hosted fields
Creer que GDPR no aplica por estar fuera de la UE	Aplica si tratas datos de residentes UE; revisa Art.3
Confundir cumplimiento con seguridad	Cumplir no garantiza estar seguro; es un mínimo
No tener DPA con proveedores	GDPR lo exige entre responsable y encargado; fírmalo
Notificar tarde una brecha	GDPR exige 72 h; ten el procedimiento listo antes del incidente

Preguntas frecuentes

? ¿Cumplir PCI-DSS me hace cumplir GDPR? No. Se solapan en algunos controles (cifrado, acceso), pero protegen cosas distintas: PCI los datos de tarjeta, GDPR los datos personales en general.

? ¿PCI-DSS es una ley? No, es un estándar contractual impuesto por las marcas de tarjeta (Visa, Mastercard, etc.). Su incumplimiento acarrea multas y pérdida de la capacidad de procesar pagos.

? ¿Qué cambió en PCI DSS v4.0? Más flexibilidad (enfoque personalizado), MFA reforzado, requisitos de anti-phishing y controles adicionales que entraron plenamente en vigor en 2025.

? ¿HIPAA me afecta si no estoy en EE. UU.? Solo si tratas PHI de entidades cubiertas estadounidenses. Para salud en la UE aplica GDPR con categorías especiales (Art.9).

Referencias

- GDPR — Reglamento (UE) 2016/679. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- HIPAA Security Rule (HHS). <https://www.hhs.gov/hipaa/for-professionals/security/index.html>
- PCI DSS v4.0 (PCI SSC). https://www.pcisecuritystandards.org/document_library/
- PCI SAQ (Self-Assessment Questionnaires). <https://www.pcisecuritystandards.org/>
- (ISC)² CISSP Official Study Guide, dominios 1 y 2.

Siguiente clase

Clase 282 - Políticas, estándares y procedimientos